



# Herzlich Willkommen Block2

Archivierung - Backup- und Restore Lösungen  
ABRL.TA1A



April 2026 / Mevluet Polat

### UNIT 2: RANSOMWARE (TEIL 2) & DATENKLASSIFIZIERUNG I



Unit 2 – Ransomware (Teil 2) und Datenklassifizierung I

Ransomware-Erkennung und -Analyse

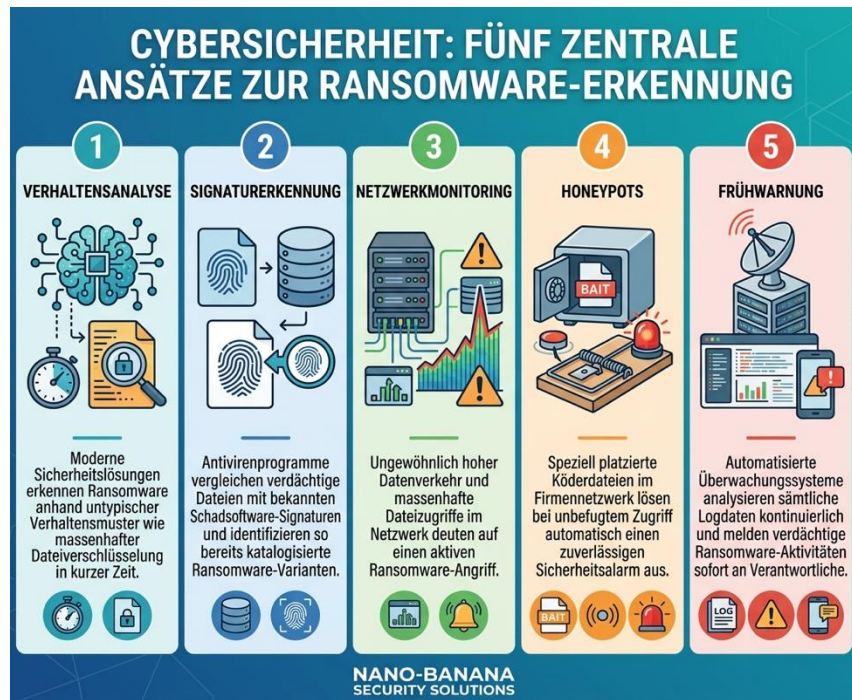
Incident Response und Wiederherstellung nach Ransomware

Grundlagen der Datenklassifizierung

Klassifizierungskriterien für Applikationen und Datenbestände

# Ransomware-Erkennung und -Analyse

## Erkennungsmethoden für Ransomware



**Verhaltensanalyse:** Moderne Sicherheitslösungen erkennen Ransomware anhand untypischer Verhaltensmuster wie massenhafter Dateiverschlüsselung in kurzer Zeit.

**Signaturerkennung:** Antivirenprogramme vergleichen verdächtige Dateien mit bekannten Schadsoftware-Signaturen und identifizieren so bereits katalogisierte Ransomware-Varianten.

**Netzwerkmonitoring:** Ungewöhnlich hoher Datenverkehr und massenhafte Dateizugriffe im Netzwerk deuten auf einen aktiven Ransomware-Angriff.

**Honeypots:** Speziell platzierte Köderdateien im Firmennetzwerk lösen bei unbefugtem Zugriff automatisch einen zuverlässigen Sicherheitsalarm aus.

**Frühwarnung:** Automatisierte Überwachungssysteme analysieren sämtliche Logdaten kontinuierlich und melden verdächtige Ransomware-Aktivitäten sofort an Verantwortliche.

# Ransomware-Erkennung und -Analyse

## Indicators of Compromise bei Ransomware

### Archivierung - Backup- und Restore Lösungen

single-board computer

#### 01 IoC-Definition



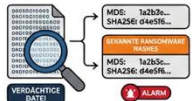
Indicators of Compromise beschreiben technische Hinweise, die auf eine erfolgte Systemkompromittierung hinweisen können.



#### 02 Dateihashes



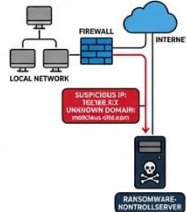
Bekannte Hashwerte identifizierter Ransomware ermöglichen einen automatisierten Abgleich mit verdächtigen Dateien auf Systemen.



#### 03 Netzwerkindikatoren



Verdächtige IP-Adressen und unbekannte Domännennamen in Verbindungsprotokollen deuten auf Kommunikation mit Ransomware-Kontrollservern hin.



#### 04 Dateiveränderungen & Protokollanalyse



Massenhafte Umbenennung von Dateien in kurzer Zeit ist ein eindeutiges Erkennungsmerkmal aktiver Ransomware.



Regelmässige Auswertung von Ereignisprotokollen hilft Unternehmen dabei, Indicators of Compromise frühzeitig zu erkennen.



mpol solutions

**IoC-Definition:** Indicators of Compromise beschreiben technische Hinweise, die auf eine erfolgte Systemkompromittierung hinweisen können.

**Dateihashes:** Bekannte Hashwerte identifizierter Ransomware ermöglichen einen automatisierten Abgleich mit verdächtigen Dateien auf Systemen.

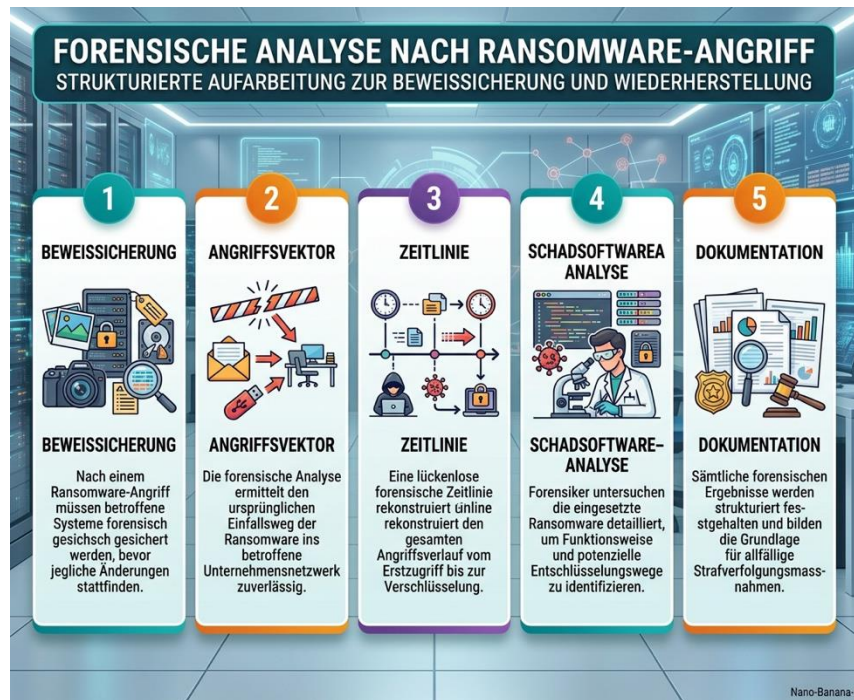
**Netzwerkindikatoren:** Verdächtige IP-Adressen und unbekannte Domännennamen in Verbindungsprotokollen deuten auf Kommunikation mit Ransomware-Kontrollservern hin.

**Dateiveränderungen:** Massenhafte Umbenennung von Dateien in kurzer Zeit ist ein eindeutiges Erkennungsmerkmal aktiver Ransomware.

**Protokollanalyse:** Regelmässige Auswertung von Ereignisprotokollen hilft Unternehmen dabei, Indicators of Compromise frühzeitig zu erkennen.

# Ransomware-Erkennung und -Analyse

## Forensische Analyse nach Ransomware-Angriffen



**Beweissicherung:** Nach einem Ransomware-Angriff müssen betroffene Systeme forensisch gesichert werden, bevor jegliche Änderungen stattfinden.

**Angriffsvektor:** Die forensische Analyse ermittelt den ursprünglichen Einfallsweg der Ransomware ins betroffene Unternehmensnetzwerk zuverlässig.

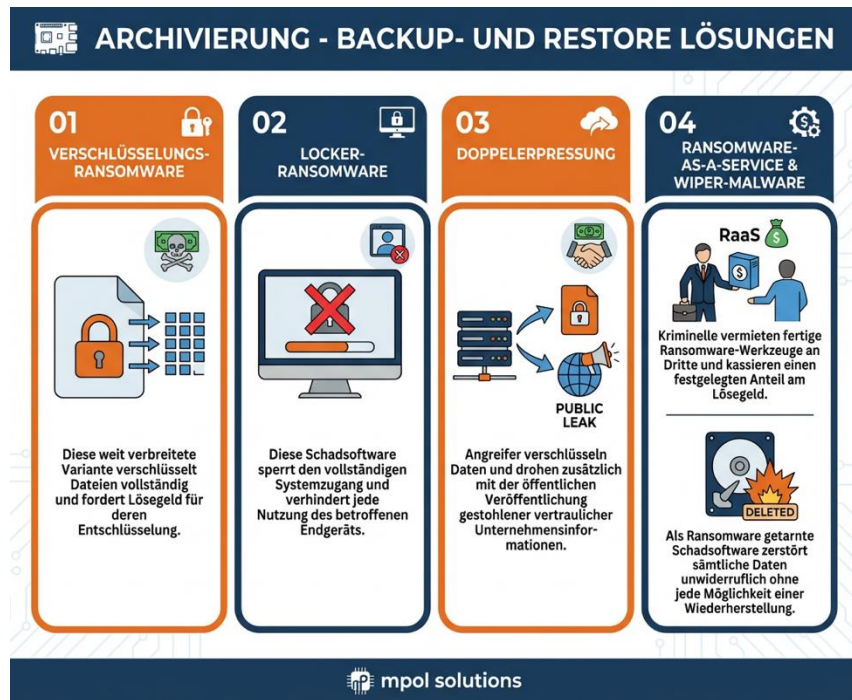
**Zeitlinie:** Eine lückenlose forensische Zeitlinie rekonstruiert den gesamten Angriffsverlauf vom Erstzugriff bis zur Verschlüsselung.

**Schadsoftwareanalyse:** Forensiker untersuchen die eingesetzte Ransomware detailliert, um Funktionsweise und potenzielle Entschlüsselungswege zu identifizieren.

**Dokumentation:** Sämtliche forensischen Ergebnisse werden strukturiert festgehalten und bilden die Grundlage für allfällige Strafverfolgungsmassnahmen.

# Ransomware-Erkennung und -Analyse

## Ransomware-Typen und ihre Merkmale



**Verschlüsselungs-Ransomware:** Diese weit verbreitete Variante verschlüsselt Dateien vollständig und fordert Lösegeld für deren Entschlüsselung.

**Locker-Ransomware:** Diese Schadsoftware sperrt den vollständigen Systemzugang und verhindert jede Nutzung des betroffenen Endgeräts.

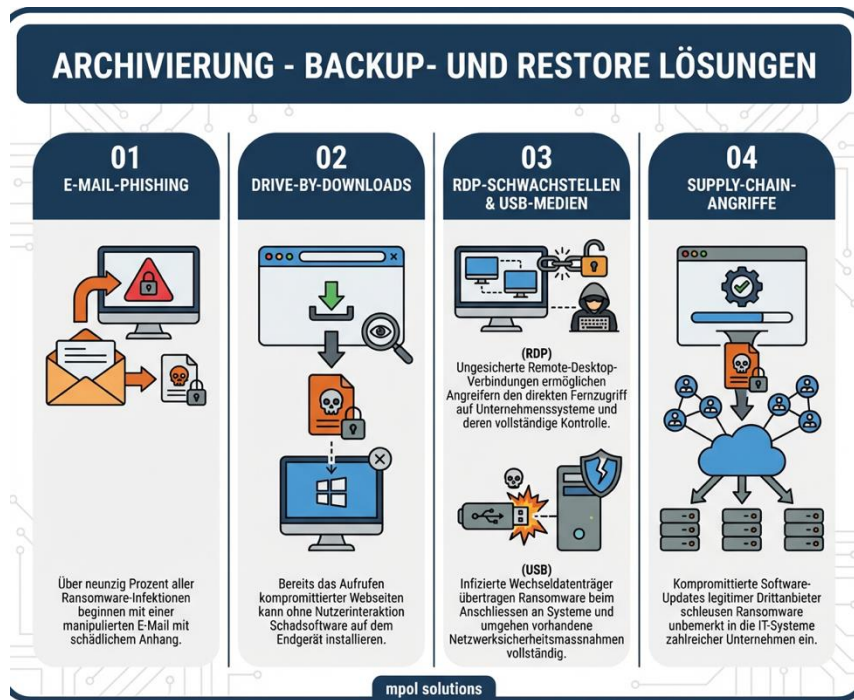
**Doppelerpressung:** Angreifer verschlüsseln Daten und drohen zusätzlich mit der öffentlichen Veröffentlichung gestohlener vertraulicher Unternehmensinformationen.

**Ransomware-as-a-Service:** Kriminelle vermieten fertige Ransomware-Werkzeuge an Dritte und kassieren einen festgelegten Anteil am Lösegeld.

**Wiper-Malware:** Als Ransomware getarnte Schadsoftware zerstört sämtliche Daten unwiderruflich ohne jede Möglichkeit einer Wiederherstellung.

# Ransomware-Erkennung und -Analyse

## Analyse typischer Angriffsvektoren



**E-Mail-Phishing:** Über neunzig Prozent aller Ransomware-Infektionen beginnen mit einer manipulierten E-Mail mit schädlichem Anhang.

**Drive-by-Downloads:** Bereits das Aufrufen kompromittierter Webseiten kann ohne Nutzerinteraktion Schadsoftware auf dem Endgerät installieren.

**RDP-Schwachstellen:** Ungesicherte Remote-Desktop-Verbindungen ermöglichen Angreifern den direkten Fernzugriff auf Unternehmenssysteme und deren vollständige Kontrolle.

**USB-Medien:** Infizierte Wechseldatenträger übertragen Ransomware beim Anschliessen an Systeme und umgehen vorhandene Netzwerksicherheitsmassnahmen vollständig.

**Supply-Chain-Angriffe:** Kompromittierte Software-Updates legitimer Drittanbieter schleusen Ransomware unbemerkt in die IT-Systeme zahlreicher Unternehmen ein.

# Ransomware-Erkennung und -Analyse

## Monitoring und Frühwarnsysteme

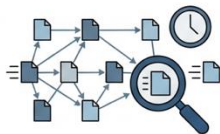
### SIEM-Systeme und Sicherheitsüberwachung

#### SIEM-Systeme



SIEM-Lösungen korrelieren Sicherheitseignisse aus verschiedenen Quellen zentral und erkennen komplexe Angriffsmuster zuverlässig automatisiert.

#### Echtzeitüberwachung



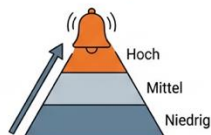
Kontinuierliche Echtzeitüberwachung aller Netzwerkaktivitäten ermöglicht die sofortige Erkennung verdächtiger Vorgänge und schnelle Reaktionsmassnahmen.

#### Anomalieerkennung



Intelligente Algorithmen erkennen Abweichungen vom normalen Systemverhalten und melden potenzielle Ransomware-Aktivitäten sofort automatisiert.

#### Alarmmanagement



Definierte Eskalationsstufen stellen sicher, dass Alarmmeldungen zeitnah an die zuständigen Sicherheitsverantwortlichen weitergeleitet werden.

#### Threat-Intelligence



Aktuelle Bedrohungsinformationen aus globalen Datenbanken helfen Unternehmen dabei, neue Ransomware-Varianten frühzeitig zu erkennen.

**SIEM-Systeme:** SIEM-Lösungen korrelieren Sicherheitseignisse aus verschiedenen Quellen zentral und erkennen komplexe Angriffsmuster zuverlässig automatisiert.

**Echtzeitüberwachung:** Kontinuierliche Echtzeitüberwachung aller Netzwerkaktivitäten ermöglicht die sofortige Erkennung verdächtiger Vorgänge und schnelle Reaktionsmassnahmen.

**Anomalieerkennung:** Intelligente Algorithmen erkennen Abweichungen vom normalen Systemverhalten und melden potenzielle Ransomware-Aktivitäten sofort automatisiert.

**Alarmmanagement:** Definierte Eskalationsstufen stellen sicher, dass Alarmmeldungen zeitnah an die zuständigen Sicherheitsverantwortlichen weitergeleitet werden.

**Threat-Intelligence:** Aktuelle Bedrohungsinformationen aus globalen Datenbanken helfen Unternehmen dabei, neue Ransomware-Varianten frühzeitig zu erkennen.

# Gruppenaufgabe 1 (30 Minuten)

## Ransomware-Erkennung und -Analyse

**Szenario:** Die «CyberShield AG», ein IT-Sicherheitsdienstleister mit Sitz in Winterthur, betreut über 40 KMU-Kunden in der Deutschschweiz. In den letzten drei Monaten haben zwei Kunden schwere Ransomware-Angriffe erlitten, obwohl beide über Antivirensoftware verfügten. Als internes Analyseteam der CyberShield AG sollen Sie die Angriffe rekonstruieren, die eingesetzten Erkennungsmethoden bewerten und ein verbessertes Erkennungskonzept für die Kundenbasis entwickeln.

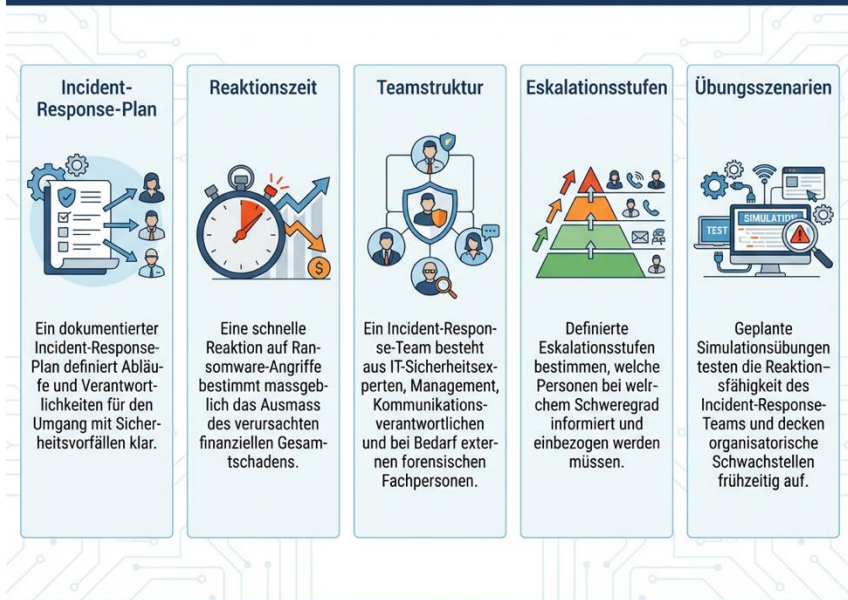
**Arbeitsauftrag:** Analysieren Sie in Ihrer Kleingruppe, warum die bestehende Antivirensoftware die Ransomware-Angriffe bei beiden Kunden nicht verhindern konnte. Bewerten Sie die Erkennungsmethoden Signaturerkennung, Verhaltensanalyse, IoC-Analyse und Netzwerkmonitoring hinsichtlich ihrer Wirksamkeit. Entwickeln Sie ein mehrstufiges Erkennungskonzept, das mindestens drei Erkennungsebenen kombiniert.

**Ergebnis:** Bereiten Sie eine Kurzpräsentation vor (max. 5 Minuten), in der Sie die Schwachstellen der bisherigen Erkennung aufzeigen und Ihr mehrstufiges Erkennungskonzept mit Begründung der gewählten Ebenen vorstellen.

# Incident Response und Wiederherstellung

## Grundlagen des Incident Response

### Archivierung – Backup- und Restore-Lösungen



**Incident-Response-Plan:** Ein dokumentierter Incident-Response-Plan definiert Abläufe und Verantwortlichkeiten für den Umgang mit Sicherheitsvorfällen klar.

**Reaktionszeit:** Eine schnelle Reaktion auf Ransomware-Angriffe bestimmt massgeblich das Ausmass des verursachten finanziellen Gesamtschadens.

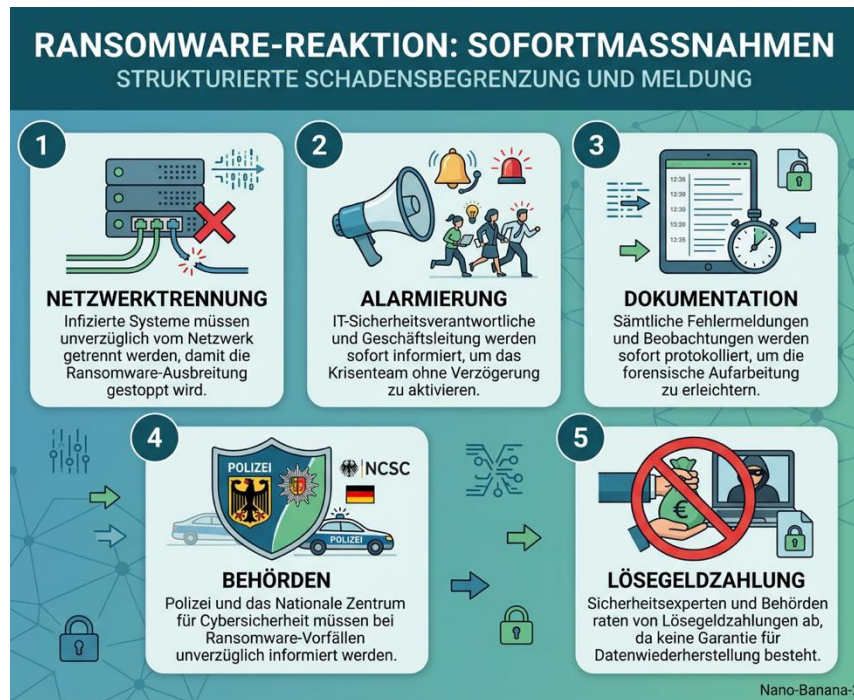
**Teamstruktur:** Ein Incident-Response-Team besteht aus IT-Sicherheitsexperten, Management, Kommunikationsverantwortlichen und bei Bedarf externen forensischen Fachpersonen.

**Eskalationsstufen:** Definierte Eskalationsstufen bestimmen, welche Personen bei welchem Schweregrad informiert und einbezogen werden müssen.

**Übungsszenarien:** Geplante Simulationsübungen testen die Reaktionsfähigkeit des Incident-Response-Teams und decken organisatorische Schwachstellen frühzeitig auf.

# Incident Response und Wiederherstellung

## Sofortmassnahmen bei Ransomware-Angriffen



**Netzwerktrennung:** Infizierte Systeme müssen unverzüglich vom Netzwerk getrennt werden, damit die Ransomware-Ausbreitung gestoppt wird.

**Alarmierung:** IT-Sicherheitsverantwortliche und Geschäftsleitung werden sofort informiert, um das Krisenteam ohne Verzögerung zu aktivieren.

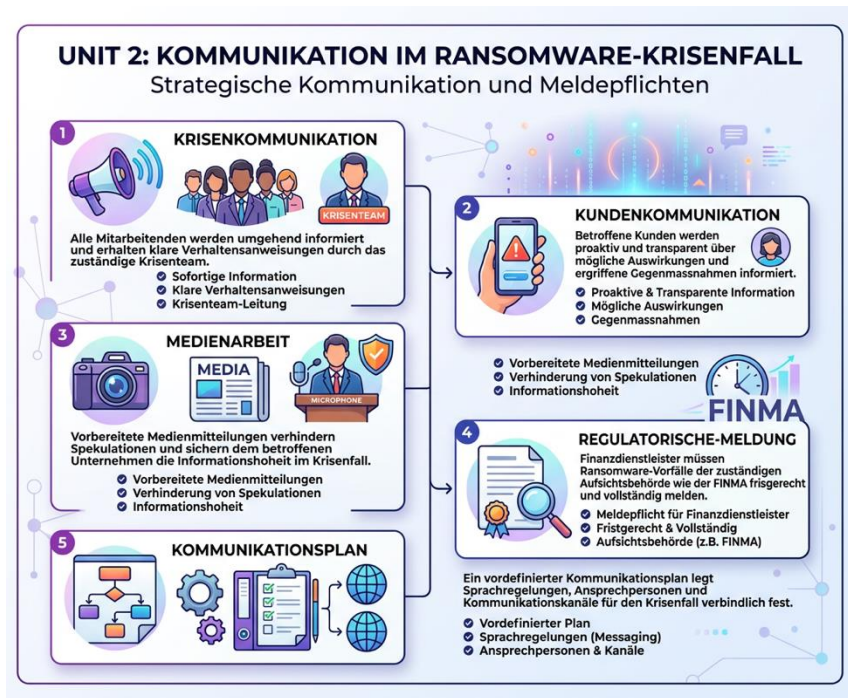
**Dokumentation:** Sämtliche Fehlermeldungen und Beobachtungen werden sofort protokolliert, um die forensische Aufarbeitung zu erleichtern.

**Behörden:** Polizei und das Nationale Zentrum für Cybersicherheit müssen bei Ransomware-Vorfällen unverzüglich informiert werden.

**Lösegeldzahlung:** Sicherheitsexperten und Behörden raten von Lösegeldzahlungen ab, da keine Garantie für Datenwiederherstellung besteht.

# Incident Response und Wiederherstellung

## Kommunikation im Krisenfall



**Krisenkommunikation:** Alle Mitarbeitenden werden umgehend informiert und erhalten klare Verhaltensanweisungen durch das zuständige Krisenteam.

**Kundenkommunikation:** Betroffene Kunden werden proaktiv und transparent über mögliche Auswirkungen und ergriffene Gegenmassnahmen informiert.

**Medienarbeit:** Vorbereitete Medienmitteilungen verhindern Spekulationen und sichern dem betroffenen Unternehmen die Informationshoheit im Krisenfall.

**Regulatorische-Meldung:** Finanzdienstleister müssen Ransomware-Vorfälle der zuständigen Aufsichtsbehörde wie der FINMA fristgerecht und vollständig melden.

**Kommunikationsplan:** Ein vordefinierter Kommunikationsplan legt Sprachregelungen, Ansprechpersonen und Kommunikationskanäle für den Krisenfall verbindlich fest.

# Incident Response und Wiederherstellung

## Wiederherstellungsstrategien nach Ransomware



**Priorisierung:** Geschäftskritische Systeme haben bei der Wiederherstellung höchste Priorität, um den Betriebsablauf schnellstmöglich wiederherzustellen.

**Neuinstallation:** Betroffene Systeme werden vollständig neu aufgesetzt, da verschlüsselte Installationen versteckte Schadsoftware enthalten können.

**Backup-Verifizierung:** Verfügbare Backups werden vor der Wiederherstellung auf Vollständigkeit, Konsistenz und Schadsoftwarefreiheit sorgfältig geprüft.

**Stufenweise-Inbetriebnahme:** Wiederhergestellte Systeme werden schrittweise aktiviert und nach jedem Schritt auf Auffälligkeiten gründlich überprüft.

**Monitoring:** Wiederhergestellte Systeme werden nach Inbetriebnahme mindestens dreissig Tage lang intensiv und lückenlos überwacht.

# Incident Response und Wiederherstellung

## Umgang mit Lösegeldforderungen

### RANSOMWARE-ZAHLUNG: GRÜNDE GEGEN DIE LÖSEGELDZAHLUNG

BEHÖRDEN- UND EXPERTENRAT: KEIN LÖSEGELD ZAHLEN



**Grundsatz:** Behörden und Sicherheitsexperten raten klar davon ab, Lösegeldforderungen nachzukommen, da keine Entschlüsselungsgarantie besteht.

**Keine-Garantie:** Eine Lösegeldzahlung garantiert nicht, dass Angreifer den Entschlüsselungsschlüssel bereitstellen oder Daten tatsächlich freigeben.

**Finanzierung:** Lösegeldzahlungen finanzieren kriminelle Organisationen direkt und ermöglichen die Entwicklung neuer und gefährlicherer Ransomware-Varianten.

**Rechtslage:** Zahlungen an sanktionierte kriminelle Gruppierungen können für betroffene Unternehmen schwerwiegende strafrechtliche Konsequenzen verursachen.

**Alternativen:** Unternehmen sollten stattdessen in Offline-Backups, Immutable-Storage und Incident-Response-Pläne investieren, um Erpressbarkeit zu verhindern.

# Incident Response und Wiederherstellung

## Nachbereitung und Lessons Learned



**Nachbereitung:** Nach einem Ransomware-Vorfall führt das Incident-Response-Team eine strukturierte Nachbereitung mit allen Beteiligten durch.

**Schwachstellenanalyse:** Identifizierte Sicherheitslücken werden dokumentiert, priorisiert und durch gezielte technische sowie organisatorische Massnahmen geschlossen.

**Prozessverbesserung:** Gewonnene Erkenntnisse fließen in die Verbesserung bestehender Sicherheitsprozesse, Notfallpläne und Backup-Strategien direkt ein.

**Schulung:** Mitarbeitende absolvieren nach dem Vorfall obligatorische Schulungen zur Erkennung und Abwehr von Ransomware-Bedrohungen.

**Berichterstattung:** Ein detaillierter Abschlussbericht dokumentiert Vorfallverlauf, ergriffene Massnahmen und abgeleitete Verbesserungen für die Geschäftsleitung.

## Gruppenaufgabe 2: (30 Minuten)

### Incident Response und Wiederherstellung nach Ransomware

**Szenario:** Die «LogiTrans AG», ein Logistikunternehmen mit 120 Mitarbeitenden und Sitz in Basel, wurde am Sonntagabend Opfer eines Ransomware-Angriffs. Das ERP-System, die Lagerverwaltung und sämtliche Kundendatenbanken sind verschlüsselt. Die Angreifer fordern 30 Bitcoins innerhalb von 48 Stunden. Die LogiTrans AG hat keinen dokumentierten Notfallplan. Als externer IT-Krisenberater sollen Sie die Sofortmassnahmen koordinieren, die Kommunikation strukturieren und einen Wiederherstellungsplan erstellen.

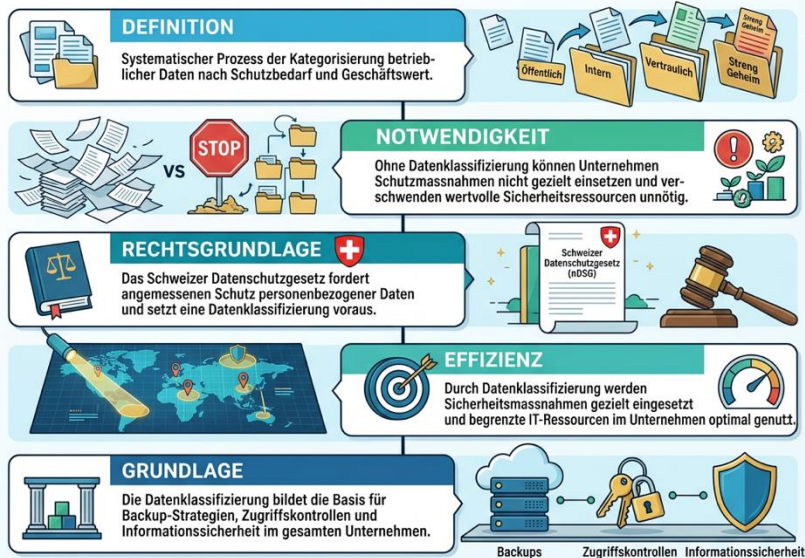
**Arbeitsauftrag:** Erarbeiten Sie in Ihrer Kleingruppe einen vollständigen Krisenreaktionsplan für die LogiTrans AG. Definieren Sie die Sofortmassnahmen für die ersten 60 Minuten, erstellen Sie einen Kommunikationsplan für Mitarbeitende, Kunden, Behörden und Medien, und entwickeln Sie einen phasenweisen Wiederherstellungsplan für die kritischsten Systeme.

**Ergebnis:** Bereiten Sie eine Kurzpräsentation vor (max. 5 Minuten), in der Sie die drei wichtigsten Sofortmassnahmen, Ihren Kommunikationsplan und die Reihenfolge der Systemwiederherstellung mit Begründung vorstellen.

# Grundlagen der Datenklassifizierung

## Definition und Bedeutung

### DATENKLASSIFIZIERUNG: SYSTEMATISCHE KATEGORISIERUNG FÜR MEHR SICHERHEIT



**Definition:** Datenklassifizierung beschreibt den systematischen Prozess der Kategorisierung betrieblicher Daten nach Schutzbedarf und Geschäftswert.

**Notwendigkeit:** Ohne Datenklassifizierung können Unternehmen Schutzmassnahmen nicht gezielt einsetzen und verschwenden wertvolle Sicherheitsressourcen unnötig.

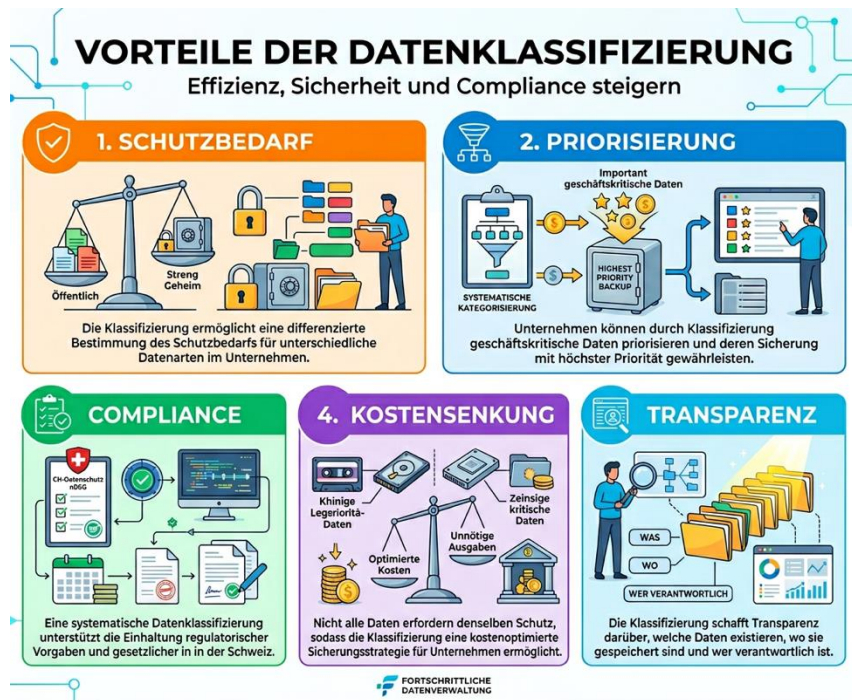
**Rechtsgrundlage:** Das Schweizer Datenschutzgesetz fordert angemessenen Schutz personenbezogener Daten und setzt eine Datenklassifizierung voraus.

**Effizienz:** Durch Datenklassifizierung werden Sicherheitsmassnahmen gezielt eingesetzt und begrenzte IT-Ressourcen im Unternehmen optimal genutzt.

**Grundlage:** Die Datenklassifizierung bildet die Basis für Backup-Strategien, Zugriffskontrollen und Informationssicherheit im gesamten Unternehmen.

# Grundlagen der Datenklassifizierung

## Ziele und Nutzen der Klassifizierung



**Schutzbedarf:** Die Klassifizierung ermöglicht eine differenzierte Bestimmung des Schutzbedarfs für unterschiedliche Datenarten im Unternehmen.

**Priorisierung:** Unternehmen können durch Klassifizierung geschäftskritische Daten priorisieren und deren Sicherung mit höchster Priorität gewährleisten.

**Compliance:** Eine systematische Datenklassifizierung unterstützt die Einhaltung regulatorischer Vorgaben und gesetzlicher Aufbewahrungspflichten in der Schweiz.

**Kostensenkung:** Nicht alle Daten erfordern denselben Schutz, sodass die Klassifizierung eine kostenoptimierte Sicherungsstrategie für Unternehmen ermöglicht.

**Transparenz:** Die Klassifizierung schafft Transparenz darüber, welche Daten existieren, wo sie gespeichert sind und wer verantwortlich ist.

# Grundlagen der Datenklassifizierung

## Klassifizierungsstufen und Schutzbedarf

### DATENKLASSIFIZIERUNG: SYSTEMATISCHE KATEGORISIERUNG FÜR MEHR SICHERHEIT



**Öffentlich:** Öffentliche Daten sind frei zugänglich und erfordern keinen besonderen Schutz hinsichtlich Vertraulichkeit oder eingeschränktem Zugriff.

**Intern:** Interne Daten sind für Mitarbeitende bestimmt und erfordern grundlegende Schutzmassnahmen gegen unbefugten Zugriff von aussen.

**Vertraulich:** Vertrauliche Daten erfordern erhöhten Schutz und dürfen nur berechtigten Personen mit nachgewiesenem Bedarf zugänglich sein.

**Streng-vertraulich:** Streng vertrauliche Daten unterliegen höchsten Sicherheitsanforderungen und erfordern Verschlüsselung sowie strenge Zugriffskontrollen.

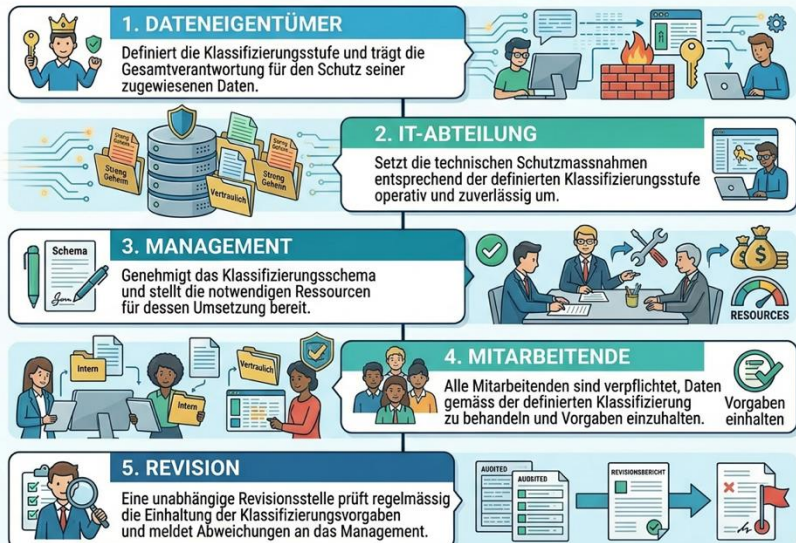
**Stufenmodell:** Ein klar definiertes Stufenmodell ermöglicht einheitliche Schutzanforderungen und erleichtert die unternehmensweit konsistente Umsetzung.

# Grundlagen der Datenklassifizierung

## Rollen und Verantwortlichkeiten

### DATENKLASSIFIZIERUNG: ROLLEN UND VERANTWORTLICHKEITEN

WER MACHT WAS BEIM DATENSCHUTZ?



Sicherheit fängt bei der Verantwortung an

**Dateneigentümer:** Der Dateneigentümer definiert die Klassifizierungsstufe und trägt die Gesamtverantwortung für den Schutz seiner zugewiesenen Daten.

**IT-Abteilung:** Die IT-Abteilung setzt die technischen Schutzmassnahmen entsprechend der definierten Klassifizierungsstufe operativ und zuverlässig um.

**Management:** Die Geschäftsleitung genehmigt das Klassifizierungsschema und stellt die notwendigen Ressourcen für dessen Umsetzung bereit.

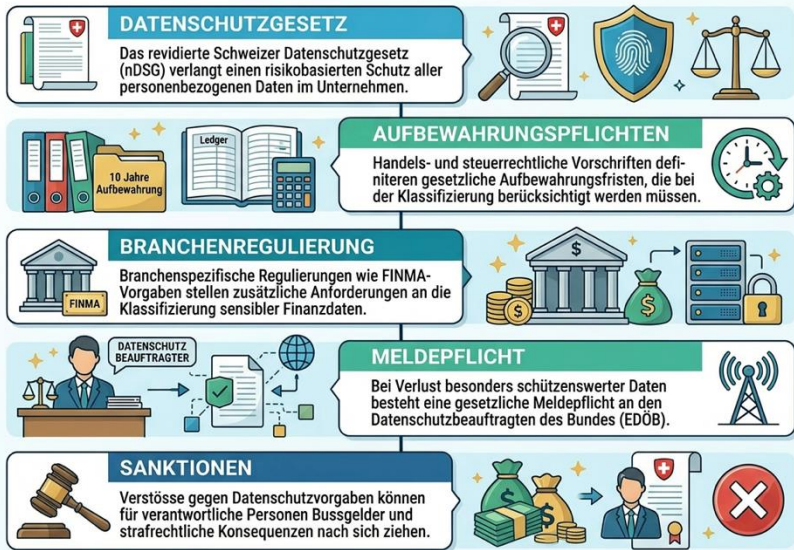
**Mitarbeitende:** Alle Mitarbeitenden sind verpflichtet, Daten gemäss der definierten Klassifizierung zu behandeln und Vorgaben einzuhalten.

**Revision:** Eine unabhängige Revisionsstelle prüft regelmässig die Einhaltung der Klassifizierungsvorgaben und meldet Abweichungen an das Management.

# Grundlagen der Datenklassifizierung

## Gesetzliche Grundlagen in der Schweiz

### DATENKLASSIFIZIERUNG: RECHTLICHE & REGULATORISCHE ANFORDERUNGEN



**Datenschutzgesetz:** Das revidierte Schweizer Datenschutzgesetz verlangt einen risikobasierten Schutz aller personenbezogenen Daten im Unternehmen.

**Aufbewahrungspflichten:** Handels- und steuerrechtliche Vorschriften definieren gesetzliche Aufbewahrungsfristen, die bei der Klassifizierung berücksichtigt werden müssen.

**Branchenregulierung:** Branchenspezifische Regulierungen wie FINMA-Vorgaben stellen zusätzliche Anforderungen an die Klassifizierung sensibler Finanzdaten.

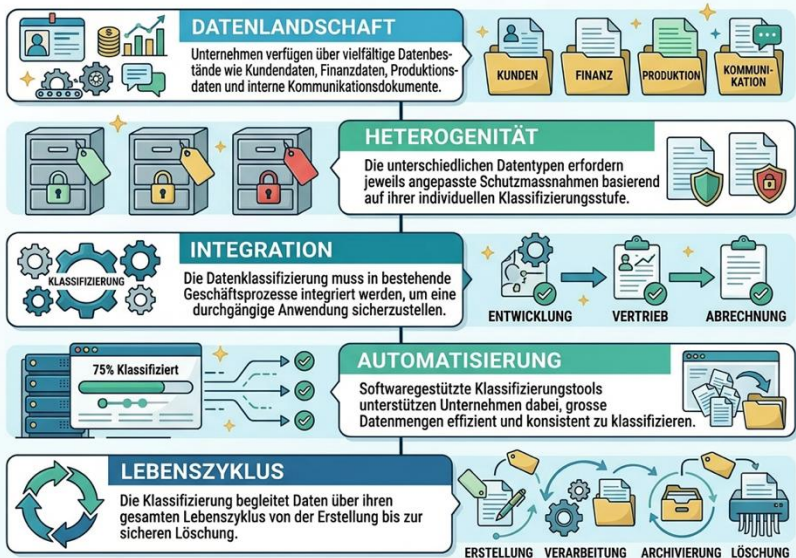
**Meldepflicht:** Bei Verlust besonders schützenswerter Daten besteht eine gesetzliche Meldepflicht an den Datenschutzbeauftragten des Bundes.

**Sanktionen:** Verstösse gegen Datenschutzvorgaben können für verantwortliche Personen Bussgelder und strafrechtliche Konsequenzen nach sich ziehen.

# Grundlagen der Datenklassifizierung

## Datenklassifizierung im Unternehmenskontext

### DATENKLASSIFIZIERUNG: HERAUSFORDERUNGEN & INTEGRATION.



**Datenlandschaft:** Unternehmen verfügen über vielfältige Datenbestände wie Kundendaten, Finanzdaten, Produktionsdaten und interne Kommunikationsdokumente.

**Heterogenität:** Die unterschiedlichen Datentypen erfordern jeweils angepasste Schutzmassnahmen basierend auf ihrer individuellen Klassifizierungsstufe.

**Integration:** Die Datenklassifizierung muss in bestehende Geschäftsprozesse integriert werden, um eine durchgängige Anwendung sicherzustellen.

**Automatisierung:** Softwaregestützte Klassifizierungstools unterstützen Unternehmen dabei, grosse Datenmengen effizient und konsistent zu klassifizieren.

**Lebenszyklus:** Die Klassifizierung begleitet Daten über ihren gesamten Lebenszyklus von der Erstellung bis zur sicheren Löschung.

## Gruppenaufgabe 3: (30 Minuten)

### Grundlagen der Datenklassifizierung

**Szenario:** Die «SwissLegal AG», eine mittelgrosse Anwaltskanzlei mit 45 Mitarbeitenden in Bern, hat bisher keine systematische Datenklassifizierung. Mandantendaten, interne Verwaltungsdokumente, Marketingmaterialien und Finanzdaten werden alle gleich behandelt – dieselbe Backup-Frequenz, derselbe Zugriffsschutz. Der neue IT-Leiter hat den Auftrag, ein Datenklassifizierungsschema einzuführen. Als externe Beratungsgruppe unterstützen Sie ihn bei der Entwicklung des Schemas.

**Arbeitsauftrag:** Erarbeiten Sie in Ihrer Kleingruppe ein vollständiges Datenklassifizierungsschema für die «SwissLegal AG». Definieren Sie mindestens vier Klassifizierungsstufen mit jeweiligen Schutzmassnahmen, ordnen Sie die typischen Datenarten der Kanzlei den Stufen zu, und definieren Sie die Rollen und Verantwortlichkeiten für die Umsetzung.

**Ergebnis:** Erstellen Sie ein Handout (1–2 Seiten), das das Klassifizierungsschema, die Zuordnung der Datenarten und das Rollenmodell übersichtlich darstellt und dem IT-Leiter als Umsetzungsgrundlage dient.

# Klassifizierungskriterien

## Klassifizierung nach Datenvolumen

### DATENSICHERUNGSKONZEPT: ANALYSE UND PLANUNG



**VOLUMENANALYSE**  
Das Datenvolumen bestimmt massgeblich die Anforderungen an Speicherkapazität, Backup-Dauer und benötigte Übertragungsbandbreite des Sicherungssystems.



**WACHSTUMSPROGNOSE**  
Eine realistische **Wachstumsprognose** des Datenvolumens ist für die langfristige Planung der Speicherinfrastruktur entscheidend.



**UMGANG MIT GROSSEN DATENMENGEN**  
Applikationen mit grossem Datenvolumen erfordern leistungsfähige Backup-Systeme und breitbandige **Netzwerkverbindungen** für zeitgerechte Sicherungen.



**DATENKOMPRIMIERUNG**  
**Datenkomprimierung** reduziert das effektive Sicherungsvolumen und verkürzt die benötigte Backup-Dauer bei grossen Datenbeständen erheblich.



**KAPAZITÄTSPLANUNG**  
Auf Basis des klassifizierten Datenvolumens wird die notwendige Speicherkapazität für Primär- und Backup-Systeme berechnet.

Primär-speicher  
Backup-Speicher

**Volumenanalyse:** Das Datenvolumen bestimmt massgeblich die Anforderungen an Speicherkapazität, Backup-Dauer und benötigte Übertragungsbandbreite des Sicherungssystems.

**Wachstumsprognose:** Eine realistische Wachstumsprognose des Datenvolumens ist für die langfristige Planung der Speicherinfrastruktur entscheidend.

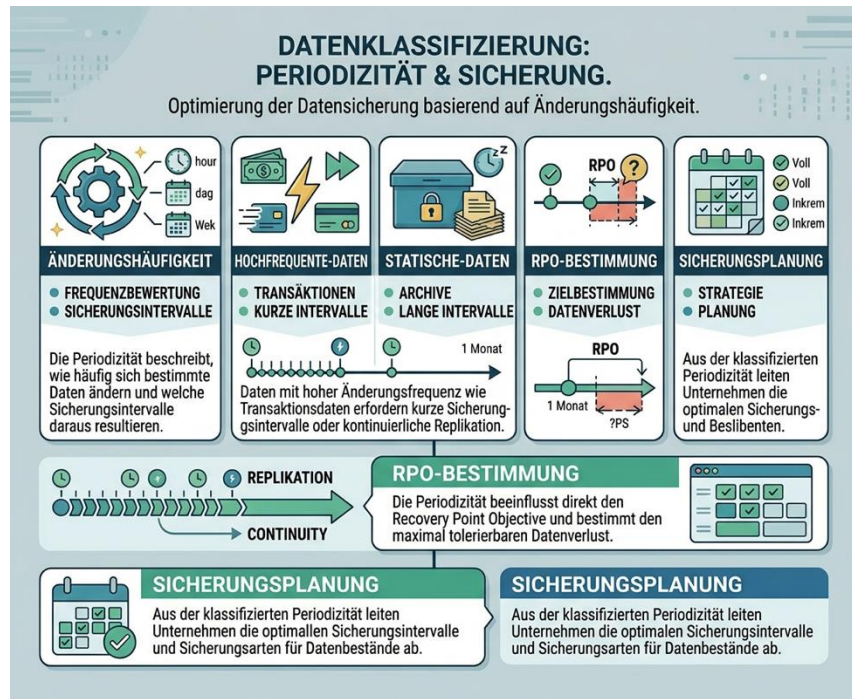
**Grosse-Datenmengen:** Applikationen mit grossem Datenvolumen erfordern leistungsfähige Backup-Systeme und breitbandige Netzwerkverbindungen für zeitgerechte Sicherungen.

**Komprimierung:** Datenkomprimierung reduziert das effektive Sicherungsvolumen und verkürzt die benötigte Backup-Dauer bei grossen Datenbeständen erheblich.

**Kapazitätsplanung:** Auf Basis des klassifizierten Datenvolumens wird die notwendige Speicherkapazität für Primär- und Backup-Systeme berechnet.

# Klassifizierungskriterien

## Klassifizierung nach Periodizität



**Änderungshäufigkeit:** Die Periodizität beschreibt, wie häufig sich bestimmte Daten ändern und welche Sicherungsintervalle daraus resultieren.

**Hochfrequente-Daten:** Daten mit hoher Änderungsfrequenz wie Transaktionsdaten erfordern kurze Sicherungsintervalle oder kontinuierliche Replikation.

**Statische-Daten:** Selten veränderte Daten wie Archivdokumente können mit längeren Sicherungsintervallen und geringerem Aufwand gesichert werden.

**RPO-Bestimmung:** Die Periodizität beeinflusst direkt den Recovery Point Objective und bestimmt den maximal tolerierbaren Datenverlust.

**Sicherungsplanung:** Aus der klassifizierten Periodizität leiten Unternehmen die optimalen Sicherungsintervalle und Sicherungsarten für Datenbestände ab.

# Klassifizierungskriterien

## Klassifizierung nach Zugriffssicherheit



**Zugriffssicherheit:** Die Zugriffssicherheit definiert, wer unter welchen Bedingungen auf bestimmte Daten zugreifen darf und muss.

**Vertraulichkeit:** Daten mit hoher Vertraulichkeitsanforderung benötigen Verschlüsselung, strenge Authentifizierung und detaillierte Protokollierung aller Zugriffe.

**Verfügbarkeit:** Geschäftskritische Daten erfordern hohe Verfügbarkeit mit definierten RTO-Werten und redundanten Speicher- und Zugriffssystemen.

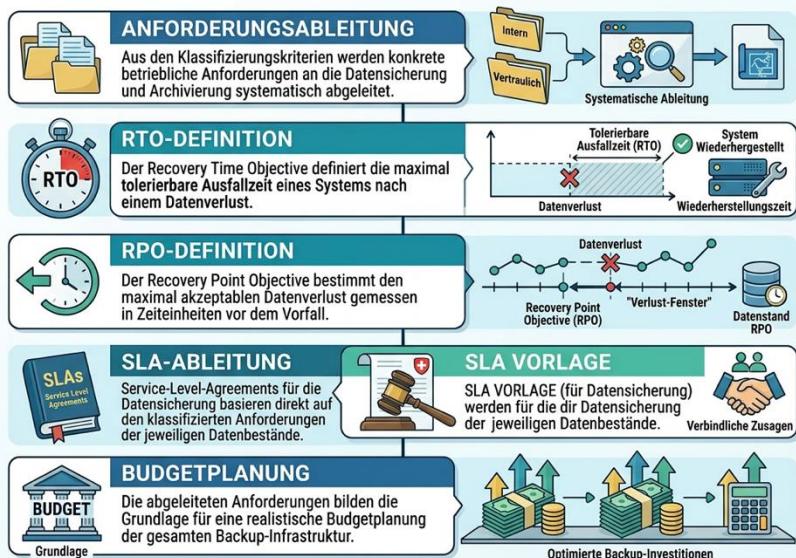
**Integrität:** Die Integrität klassifizierter Daten wird durch Prüfsummen, Versionierung und manipulationssichere Speicherverfahren dauerhaft gewährleistet.

**Zugriffskontrollen:** Rollenbasierte Zugriffskontrollen stellen sicher, dass nur autorisierte Personen entsprechend ihrer Berechtigung auf Daten zugreifen.

# Klassifizierungskriterien

## Betriebliche Anforderungen ableiten

### ANFORDERUNGSABLEITUNG NACH DATENKLASSIFIZIERUNG: VON KRITERIEN ZU KONKRETEN KONZEPTEN



**Anforderungsableitung:** Aus den Klassifizierungskriterien werden konkrete betriebliche Anforderungen an die Datensicherung und Archivierung systematisch abgeleitet.

**RTO-Definition:** Der Recovery Time Objective definiert die maximal tolerierbare Ausfallzeit eines Systems nach einem Datenverlust.

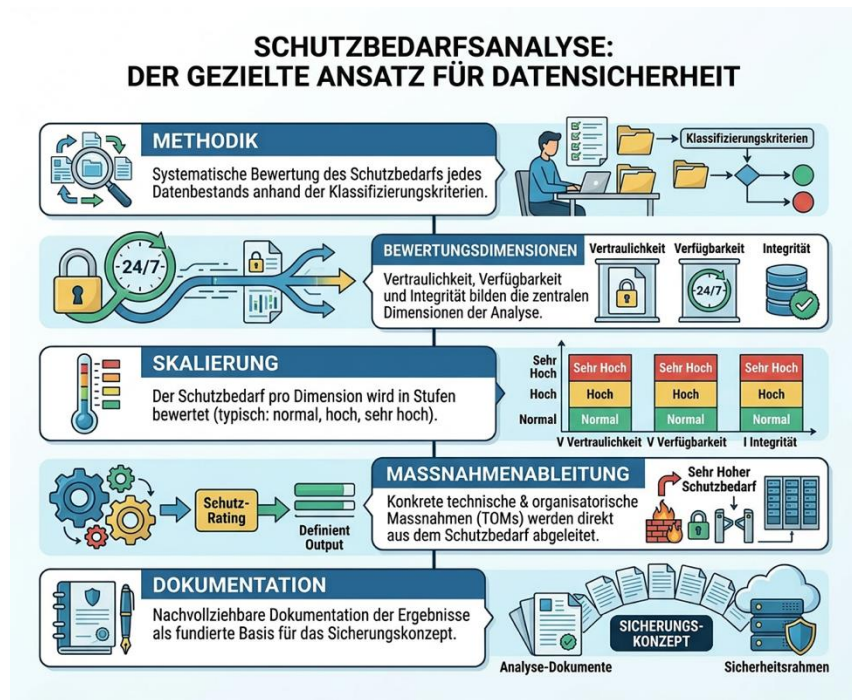
**RPO-Definition:** Der Recovery Point Objective bestimmt den maximal akzeptablen Datenverlust gemessen in Zeiteinheiten vor dem Vorfall.

**SLA-Ableitung:** Service-Level-Agreements für die Datensicherung basieren direkt auf den klassifizierten Anforderungen der jeweiligen Datenbestände.

**Budgetplanung:** Die abgeleiteten Anforderungen bilden die Grundlage für eine realistische Budgetplanung der gesamten Backup-Infrastruktur.

# Klassifizierungskriterien

## Schutzbedarfsanalyse durchführen



**Methodik:** Die Schutzbedarfsanalyse bewertet systematisch den Schutzbedarf jedes Datenbestands anhand der definierten Klassifizierungskriterien.

**Bewertungsdimensionen:** Vertraulichkeit, Verfügbarkeit und Integrität bilden die drei zentralen Dimensionen jeder durchgeführten Schutzbedarfsanalyse.

**Skalierung:** Der Schutzbedarf wird pro Dimension in Stufen bewertet, typischerweise als normal, hoch oder sehr hoch.

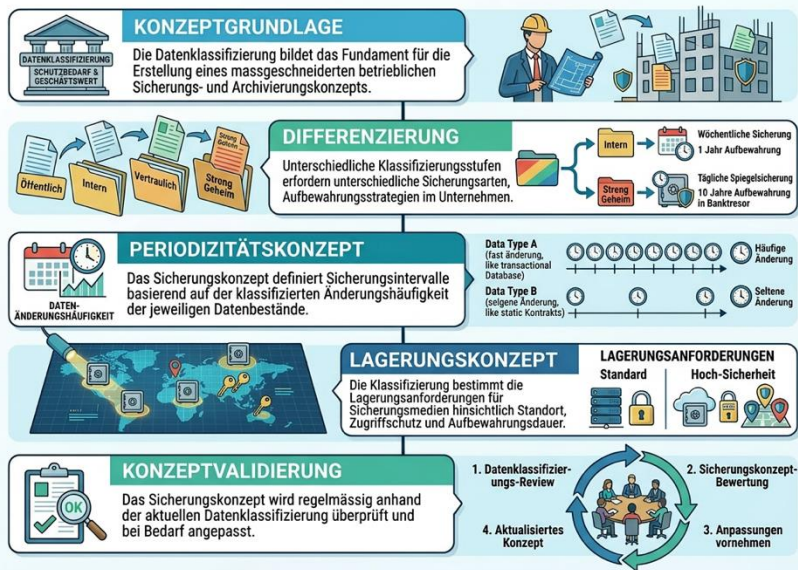
**Massnahmenableitung:** Aus dem ermittelten Schutzbedarf werden konkrete technische und organisatorische Sicherheitsmassnahmen direkt und nachvollziehbar abgeleitet.

**Dokumentation:** Die Ergebnisse der Schutzbedarfsanalyse werden nachvollziehbar dokumentiert und bilden die Basis für das Sicherungskonzept.

# Klassifizierungskriterien

## Von der Klassifizierung zum Sicherungskonzept

### SICHERUNGSKONZEPT: DER WEG ZUR MASSGESCHNEIDERTEN DATENSICHERHEIT AUF BASIS DER DATENKLASSIFIZIERUNG



**Konzeptgrundlage:** Die Datenklassifizierung bildet das Fundament für die Erstellung eines massgeschneiderten betrieblichen Sicherungs- und Archivierungskonzepts.

**Differenzierung:** Unterschiedliche Klassifizierungsstufen erfordern unterschiedliche Sicherungsarten, Sicherungsfrequenzen und Aufbewahrungsstrategien im Unternehmen.

**Periodizitätskonzept:** Das Sicherungskonzept definiert Sicherungsintervalle basierend auf der klassifizierten Änderungshäufigkeit der jeweiligen Datenbestände.

**Lagerungskonzept:** Die Klassifizierung bestimmt die Lagerungsanforderungen für Sicherungsmedien hinsichtlich Standort, Zugriffsschutz und Aufbewahrungsdauer.

**Konzeptvalidierung:** Das Sicherungskonzept wird regelmässig anhand der aktuellen Datenklassifizierung überprüft und bei Bedarf angepasst.

# Gruppenaufgabe 4

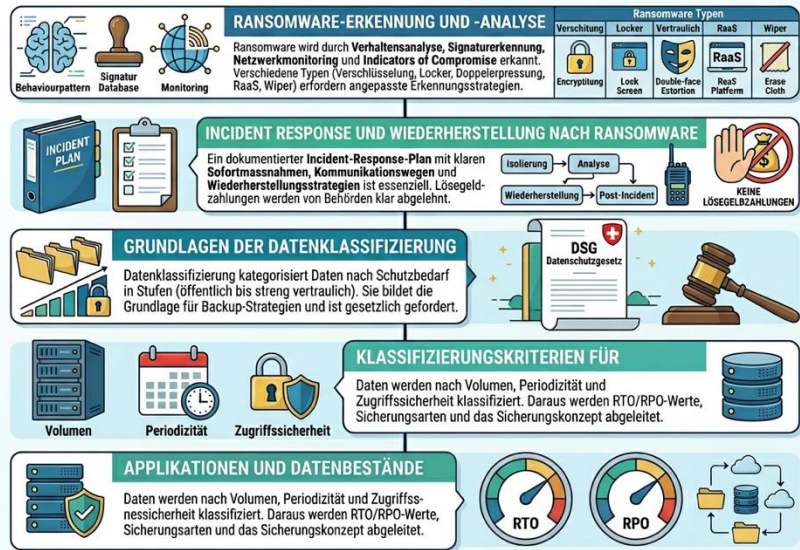
## Klassifizierungskriterien für Applikationen und Datenbestände

**Szenario:** Die «PharmaSwiss GmbH», ein mittelständisches Pharmaunternehmen mit 200 Mitarbeitenden in Zug, muss im Rahmen einer Audit-Vorbereitung erstmals eine vollständige Klassifizierung aller Applikationen und Datenbestände nach Volumen, Periodizität und Zugriffssicherheit durchführen. Als internes IT-Projektteam sollen Sie die Klassifizierungskriterien auf die wichtigsten Systeme anwenden, daraus betriebliche Anforderungen (RTO/RPO) ableiten und eine Schutzbedarfsanalyse erstellen.

**Arbeitsauftrag:** Identifizieren Sie in Ihrer Kleingruppe die fünf wichtigsten Applikationen und Datenbestände der «PharmaSwiss GmbH». Klassifizieren Sie jede Applikation nach Volumen, Periodizität und Zugriffssicherheit. Leiten Sie für jede Applikation RTO- und RPO-Werte ab und erstellen Sie eine Schutzbedarfsanalyse mit Bewertung in den Dimensionen Vertraulichkeit, Verfügbarkeit und Integrität.

**Ergebnis:** Bereiten Sie eine Kurzpräsentation vor (max. 5 Minuten), in der Sie Ihre Klassifizierungsergebnisse, die abgeleiteten RTO/RPO-Werte und die Schutzbedarfsanalyse für die drei kritischsten Applikationen vorstellen und begründen.

### GANZHEITLICHER RANSOMWARE- UND DATENSCHUTZ: VON DER ERKENNUNG ZUR WIEDERHERSTELLUNG UND KLASSTIFIZIERUNG



### Hauptkategorie 1 – Ransomware-Erkennung und -Analyse:

Ransomware wird durch Verhaltensanalyse, Signaturerkennung, Netzwerkmonitoring und Indicators of Compromise erkannt. Verschiedene Typen (Verschlüsselung, Locker, Doppelerpressung, RaaS, Wiper) erfordern angepasste Erkennungsstrategien.

### Hauptkategorie 2 – Incident Response und Wiederherstellung nach Ransomware:

Ein dokumentierter Incident-Response-Plan mit klaren Sofortmassnahmen, Kommunikationswegen und Wiederherstellungsstrategien ist essenziell. Lösegeldzahlungen werden von Behörden klar abgelehnt.

### Hauptkategorie 3 – Grundlagen der Datenklassifizierung:

Datenklassifizierung kategorisiert Daten nach Schutzbedarf in Stufen (öffentlich bis streng vertraulich). Sie bildet die Grundlage für Backup-Strategien und ist gesetzlich gefordert (DSG, Aufbewahrungspflichten).

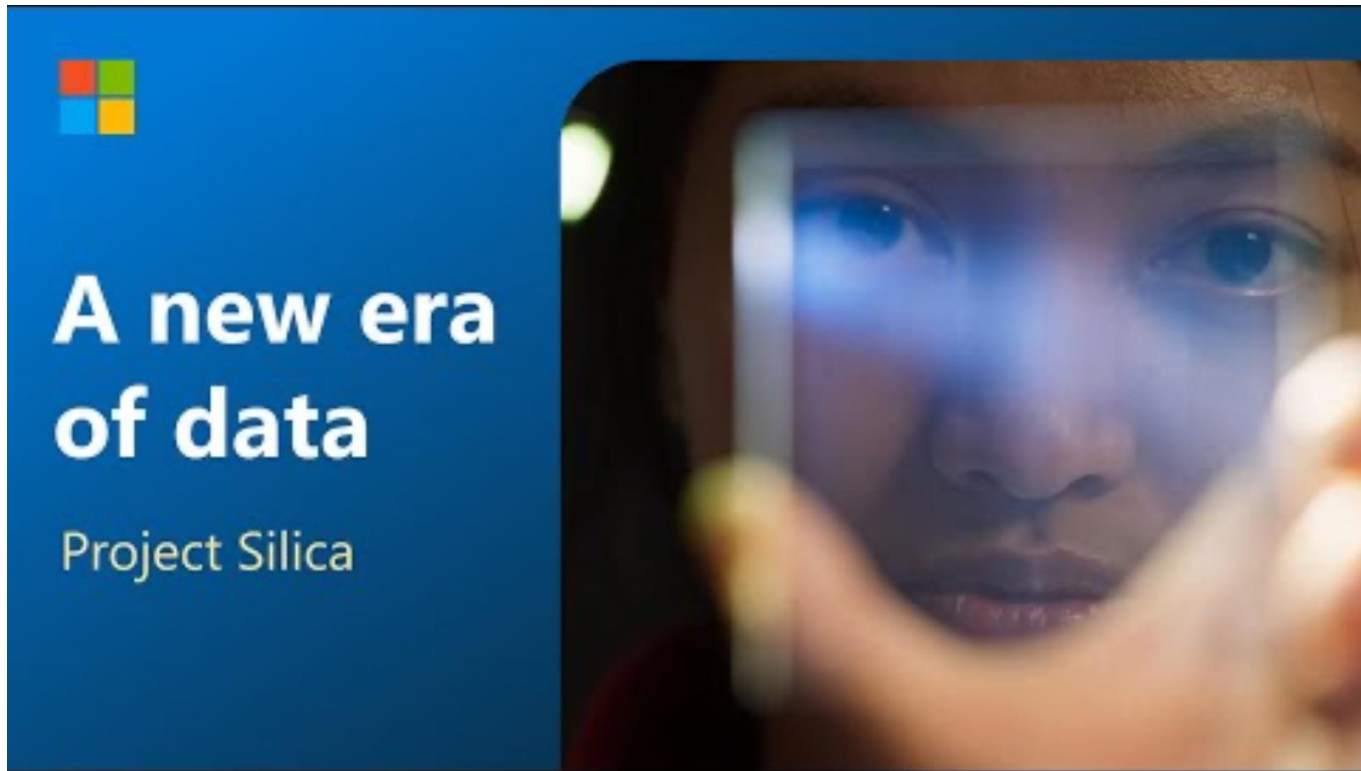
### Hauptkategorie 4 – Klassifizierungskriterien für Applikationen und Datenbestände:

Daten werden nach Volumen, Periodizität und Zugriffssicherheit klassifiziert. Daraus werden RTO/RPO-Werte, Sicherungsarten und das Sicherungskonzept abgeleitet.

# Microsoft Project Silica

Saving data into voxels for next 10 years

ipso!



# Fragen?

ipso!



**Bildquelle:** Pixabay